

PLANTILLA DE REPORTE EJECUTIVO GQM+PRAGMATIC

Estructura PowerPoint: Del Diagnóstico de Métricas a la Decisión Estratégica

Kit GQM+PRAGMATIC FISMA 2025 — Documento (f) • Versión 1.0 • Abril 2026

"Si el informe anterior les daba los números, este les dice cuánto pueden fiarse de esos números. Y eso, en ciberseguridad, es frecuentemente la diferencia entre la tranquilidad justificada y la temeridad estadística."

INFORMACIÓN GENERAL

- Título de la presentación: "Diagnóstico GQM+PRAGMATIC — Madurez en Ciberseguridad con Métricas de Calidad Verificada"
- Diapositivas: 20 principales + 6 opcionales técnicas
- Duración: 25-30 min (ejecutivo) / 50-60 min (técnico)
- Audiencias: Consejo de Dirección / Comité de Seguridad / CISO y equipo técnico
- Diferencial respecto al reporte estándar: Este reporte añade la dimensión de calidad de las métricas — no sólo "cuál es nuestro nivel" sino "cuánto podemos confiar en ese nivel"
- Paleta de colores: Azul primario #003366 | Verde fiabilidad #16A34A | Ámbar alerta #D97706 | Rojo riesgo #DC2626 | Gris evidencia #6B7280 | Naranja PRAGMATIC #EA580C

DIAPPOSITIVA 1 — PORTADA

Diseño: Fondo degradado azul oscuro a negro; tipografía blanca

- Título (42pt): "¿Cuánto podemos confiar en lo que medimos?"
- Subtítulo (26pt): "Diagnóstico de Madurez GQM+PRAGMATIC — FISMA FY2025"
- Organización y fecha (18pt, blanco 70%): "[Nombre Organización] · Abril 2026"
- Referencia de marcos (12pt, blanco 50%): "Goal-Question-Metric (Basili, 1994) + PRAGMATIC Metametrics (Brotby & Hinson, 2013) + FY2025 FISMA IG Metrics v2.0"
- Logo institucional (esquina inferior)

DIAPPOSITIVA 2 — EL PROBLEMA QUE ESTE REPORTE RESUELVE

Título: "No todos los números son iguales"

Diseño: Dos columnas comparativas

Columna izquierda (rojo) — Sin GQM+PRAGMATIC:

- "Medimos porque la auditoría lo pide"
- "El cuadro de mando tiene 47 indicadores que nadie lee"
- "Nuestro IGM es 3.2 (¿o quizás 2.8? depende de quién pregunte)"
- "Cumplimos el ENS en el papel"

Columna derecha (verde) — Con GQM+PRAGMATIC:

- "Medimos para tomar decisiones específicas"
- "12 métricas priorizadas; todas accionables y genuinas"
- "Nuestro IGM es 2.7 ± 0.2 (intervalo de confianza basado en PRAGMATIC)"
- "Sabemos qué del ENS mide algo real y qué es decoración"

Pregunta central (texto grande, centrado):

"¿Preferimos saber que no sabemos, o creer que sabemos cuando no sabemos?"

DIAPPOSITIVA 3 — MARCO METODOLÓGICO: GQM + PRAGMATIC + FISMA

Título: "Tres Capas de Rigor, Un Solo Resultado Accionable"

Diseño: Pirámide de tres niveles o diagrama de flujo vertical

Nivel 3 (base / azul oscuro): GQM+Strategies

- "Trazabilidad: Estrategia Nacional — Objetivos — Preguntas — Datos"
- Referencia: Basili, Caldiera & Rombach (1994/2014)

Nivel 2 (medio / azul medio): FISMA FY2025 Metrics

- "25 indicadores estandarizados (20 core + 5 suplementarias)"
- "10 dominios · 6 funciones CSF 2.0"
- Referencia: CIGIE/OMB/CISA, 3 abril 2025

Nivel 1 (cima / verde): PRAGMATIC Quality Filter

- "9 criterios de calidad métrica (Brotby & Hinson, 2013)"
- "Cada métrica calificada 0-90 puntos"
- "Resultado: IGM ponderado por fiabilidad real de medición"

DIAPPOSITIVA 4 — LOS 9 CRITERIOS PRAGMATIC EN 60 SEGUNDOS

Título: "PRAGMATIC: el Test de Calidad de Toda Métrica"

Diseño: 9 tarjetas en formato 3×3, cada una con letra, nombre y emoji

P — Predictivo 🎯	R — Relevante 🎯	A — Accionable ⚡
¿Anticipa problemas antes de que ocurran?	¿Le importa a quien decide?	¿Qué hago cuando el valor es bajo?
G — Genuino 🔍	M — Significativo 💡	Ac — Preciso 📐
¿Mide lo que dice medir, o un proxy?	¿Lo entiende quien necesita actuar?	¿Los datos son suficientemente exactos?

T — Oportuno 	I — Independiente 	C — Rentable 
¿Llega cuando se necesita?	¿Puede manipularse el resultado?	¿El coste justifica el beneficio?

Escala (pie de página): "Cada criterio: 0-10 puntos. Máximo: 90. Umbral de adopción recomendada: ≥ 61 "

DIAPPOSITIVA 5 — RESULTADOS PRINCIPALES: EL DOBLE IGM

Título: "¿Cuál es Nuestra Situación Real? El Doble Diagnóstico"

Diseño: Dos medidores grandes lado a lado

Medidor izquierdo (azul) — IGM Simple:

- Valor: [X.X] / 5.0
- Etiqueta: "IGM Convencional"
- Subtítulo: "Lo que dicen los datos crudos"

Medidor derecho (naranja) — IGM PRAGMATIC:

- Valor: [X.X] / 5.0
- Etiqueta: "IGM Verificado PRAGMATIC"
- Subtítulo: "Lo que los datos fiables realmente dicen"

Diferencia (centro, texto grande):

Δ = [valor] puntos
 [Si negativo]: "Las métricas poco fiables estaban inflando nuestra valoración"
 [Si positivo]: "Nuestras métricas de calidad confirman o mejoran la valoración"
 [Si ≈ 0]: "Buena consistencia entre métricas formales y su calidad real"

Score PRAGMATIC medio (recuadro inferior):

"Score PRAGMATIC medio de nuestras 25 métricas: [XX]/90 — Categoría: [★★★★☆☆]"

DIAPPOSITIVA 6 — GRÁFICO RADAR DUAL: SIMPLE VS. PRAGMATIC

Título: "El Mapa de Nuestra Madurez: Lo Declarado vs. Lo Verificado"

Gráfico de radar con 10 ejes (uno por módulo GQM):

- Serie 1 (azul): IGM Simple por módulo
- Serie 2 (naranja): IGM PRAGMATIC por módulo
- Línea umbral L4 (rojo punteado): 3.5 en todos los ejes
- Zona sombreada: diferencia entre series (área de "inflación métrica")

Texto de apoyo:

"Los módulos donde la línea azul supera significativamente a la naranja son aquellos donde la calidad de medición es más débil. Ahí no sólo hay que mejorar la madurez — hay que mejorar cómo la medimos."

DIAPOSITIVA 7 — RANKING DE MÉTRICAS POR SCORE PRAGMATIC

Título: "¿Cuáles de Nuestras Métricas Son Realmente de Confianza?"

Diseño: Gráfico de barras horizontales ordenadas por score PRAGMATIC

Top 5 métricas (barras verdes):

1. IDAM-1: MFA Implementation — 77/90 ★★★★★☆
2. CM-2: Patch MTTP Critical — 76/90 ★★★★★☆
3. ISCM-2: EDR/XDR Coverage — 75/90 ★★★★★☆
4. ISCM-3: MTTD — 73/90 ★★★★★☆
5. CM-3: Vulnerability Scanning — 72/90 ★★★★★☆

Bottom 5 métricas (barras rojas/ámbar):

- ISCM-4: CTI Integration — 56/90 ★★☆☆☆☆
- ZTA-S1/S2: Zero Trust — 59/90 ★★☆☆☆☆
- DP-1: Data Classification — 60/90 ★★☆☆☆☆
- ST-1: Training Completion — 61/90 ★★☆☆☆☆

Línea vertical verde punteada: Umbral adopción recomendada = 61/90

DIAPOSITIVA 8 — MAPA DE CALOR PRAGMATIC

Título: "El Mapa de Calor de Nuestras Métricas: Dónde Falla la Medición"

Diseño: Tabla de calor 10 módulos × 9 criterios PRAGMATIC

(Verde ≥ 8 / Ámbar = 7 / Rojo ≤ 6 para cada celda)

	P	R	A	G	M	Ac	T	I	C
Gobernanza	●	●	●	●	●	●	●	●	●
C-SCRM	●	●	●	●	●	●	●	●	●
Riesgos / Activos	●	●	●	●	●	●	●	●	●
Configuración	●	●	●	●	●	●	●	●	●
IDAM/ZTA	●	●	●	●	●	●	●	●	●
Datos/Privacidad	●	●	●	●	●	●	●	●	●
Formación	●	●	●	●	●	●	●	●	●
Monitorización	●	●	●	●	●	●	●	●	●
Respuesta IR	●	●	●	●	●	●	●	●	●
Continuidad	●	●	●	●	●	●	●	●	●

Conclusión visual: G (Genuino) y C (Rentable) son los criterios más frecuentemente en rojo — patrón sistémico universal en la medición de ciberseguridad.

DIAPOSITIVA 9 — CLASIFICACIÓN DE MÉTRICAS: LAS 4 CATEGORÍAS

Título: "¿Qué Hacemos con Cada Métrica?"

Diseño: Cuatro cuadrantes con número de métricas en cada uno

Cuadrante A — Adopción Inmediata (verde, score ≥ 71):

9 métricas → "Implementar directamente; infraestructura disponible"

IDAM-1, CM-2, ISCM-2, ISCM-3, IR-3, CM-3, IDAM-3, Gov-1, RA-2

Cuadrante B — Con Adaptación (ámbar, score 61-70):

12 métricas → "Mitigar debilidad principal antes de producir datos formales"

Gov-2, Gov-3, SCRM-1/2/3, RA-1/3, CM-1, IDAM-2, DP-2, ST-2, ISCM-1, IR-1/2, CP-1/2

Cuadrante C — Fase 2 (naranja, score 51-60):

4 métricas → "Valiosas a largo plazo; implementar en año 2-3"

ZTA-S1, ZTA-S2, DP-1, ISCM-4

Cuadrante D — Rediseñar (rojo, score < 51):

0 métricas → "Ninguna métrica FISMA FY2025 cae en esta categoría — el estándar es sólido"

DIAPOSITIVA 10 — ANÁLISIS DE CAUSA RAÍZ: POR QUÉ FALLAN LOS CRITERIOS G y T

Título: "La Tensión Estructural de la Medición en Ciberseguridad"

Diseño: Diagrama de espina de pescado o árbol de causas

Criterio G (Genuino) — por qué es débil:

- Las métricas de proceso (plan existe, formación completada) son más fáciles de medir que las de resultado
- Proxy más accesible ≠ objeto de medición real
- Resistencia cultural a medir resultados que puedan revelar problemas

Criterio T (Oportuno) — por qué es débil:

- Los procesos de seguridad (AR, DPIAs, auditorías) tienen ciclos anuales por diseño
- Los riesgos evolucionan diariamente; los datos los capturan anualmente
- Falta de automatización en la recopilación de métricas

Criterio C (Rentable) — por qué es débil en algunos dominios:

- ZTA y C-SCRM requieren capacidades especializadas costosas
- Las pruebas de continuidad son disruptivas y requieren ventanas de mantenimiento
- Los AR formales con MAGERIT consumen semanas de trabajo de expertos

Solución sistémica: Automatizar la recopilación (mejora T y C), complementar siempre con métricas de resultado (mejora G).

DIAPOSITIVA 11 — HALLAZGOS: LAS 5 MÉTRICAS CON MAYOR IMPACTO

Título: "Si Sólo Pudiéramos Mejorar 5 Cosas..."

Diseño: 5 tarjetas numeradas con código de color (verde = mejorar calidad; azul = mejorar madurez)

Hallazgo 1 (verde — mejora de calidad de medición):

Criterio G de ST-1 (Training completion)

- Score PRAGMATIC actual: 61/90 (G=5: muy débil)
- Acción: Añadir ST-2 (phishing click rate) como métrica de validación
- Impacto: Pasar de medir actividad a medir resultado; G sube a ~8

Hallazgo 2 (azul — mejora de madurez):

IDAM-1: MFA — score PRAGMATIC excelente (77/90), pero madurez baja en muchas AAPP

- La métrica es fiable: si el valor es bajo, el problema es real
- Acción: Implementar MFA universal; es la acción con mayor ROSI del portafolio

Hallazgo 3 (verde — mejora de calidad de medición):

Criterio T de RA-3 (Risk Assessment) — T=5

- El ciclo anual de AR es insuficiente para sistemas en rápida evolución
- Acción: Implementar AR continuo automatizado (risk sensing) para sistemas de alto impacto

Hallazgo 4 (azul — mejora de madurez):

CM-2: Patch MTTP — score PRAGMATIC muy alto (76/90)

- Lo que mide CM-2 es real y accionable; si el MTTP > 15 días, hay que actuar
- Acción: Automatizar el ciclo de parcheo; suscribirse a CISA KEV para priorización

Hallazgo 5 (naranja — inversión en capacidad de medición):

ZTA-S1/S2 — scores 59/90 (subjetividad del nivel ZTMM)

- Antes de implementar Zero Trust, hay que saber bien cómo medir el progreso
- Acción: Adoptar CISA ZTMM v2.0 con criterios objetivos por pilar; definir KPIs de ZT antes de iniciar despliegue

DIAPPOSITIVA 12 — ROSI CON AJUSTE GQM+PRAGMATIC

Título: "El Coste de Medir Mal: ROSI Verificado vs. ROSI Aparente"

Diseño: Tres columnas

Columna 1 (gris) — Sin métricas:

- ALE estimado: "Desconocido"
- ROSI de la inversión: "Incalculable"
- Riesgo de decisión: Muy alto (gestionar a ciegas)

Columna 2 (azul) — Con métricas convencionales (IGM Simple):

- ALE basado en IGM Simple: [X €]
- ROSI calculado: [Y%]
- Riesgo de decisión: Medio (métricas sin validación de calidad)

Columna 3 (verde) — Con métricas verificadas PRAGMATIC:

- ALE ajustado: [X' €] (diferente de columna 2 si metrics poco fiables)
- ROSI verificado: [Y'%]
- Riesgo de decisión: Bajo (decisiones basadas en métricas de calidad conocida)

Diferencia ALE (columna 2 vs. 3): "La diferencia entre el ALE convencional y el verificado es [Z €] — el valor de tener métricas en las que puedes confiar."

DIAPPOSITIVA 13 — HOJA DE RUTA: MEJORAR MADUREZ Y MÉTRICAS SIMULTÁNEAMENTE

Título: "El Doble Plan: Crecer en Madurez y en Calidad de Medición"

Diseño: Tabla de doble eje temporal × tipo de mejora

Horizonte	Mejoras de Madurez (IGM)	Mejoras de Calidad Métrica (PRAGMATIC)
Meses 1-3 (Quick Wins)	MFA universal (IDAM-1) · Parcheo automático (CM-2) · Dashboard KPIs	Añadir ST-2 a ST-1 · Automatizar recopilación IDAM-1 y CM-2
Meses 4-9 (Fundamentos)	EDR completo (ISCM-2) · PAM (IDAM-3) · Revisión IRP	AR continuo para sistemas Alto (mejora T de RA-3) · DLP para DP-1
Meses 10-18 (Madurez)	ZTA roadmap (ZTA-S1/S2) · CTI integration · ENS certificación	Objetivar niveles CISA ZTMM · Integrar CTI en SIEM automáticamente
Años 2-3 (Excelencia)	IGM ≥ 3.5 en todos los módulos	Score PRAGMATIC medio $\geq 72/90$ en toda la cartera

DIAPPOSITIVA 14 — MARCO NORMATIVO: DÓNDE ENCAJA GQM+PRAGMATIC

Título: "GQM+PRAGMATIC en el Ecosistema Normativo Español"

Diseño: Mapa de posicionamiento

ENS (RD 311/2022): "Define qué medir (medidas y controles). GQM garantiza la trazabilidad hasta sus artículos."

NIS2 (Dir. 2022/2555): "Exige proporcionalidad de medidas al riesgo. PRAGMATIC valida que las métricas que sustentan esa proporcionalidad son genuinas y precisas."

NIST CSF 2.0: "Proporciona la estructura de 6 funciones. GQM la conecta con los objetivos estratégicos de la organización."

FISMA FY2025: "Define los 25 indicadores con umbrales y niveles de madurez. El marco GQM+PRAGMATIC los califica, prioriza y pondera."

Resultado: "Un sistema de medición con base normativa triple (ENS + NIS2 + FISMA) y rigor metodológico doble (GQM + PRAGMATIC)."

DIAPPOSITIVA 15 — COMPARATIVA ESPAÑA VS. BENCHMARKS INTERNACIONALES

Título: "¿Cómo Medimos Comparado con Quienes Mejor Miden?"

Gráfico de barras con dos series por sector:

- Serie 1 (azul): IGM Simple
- Serie 2 (naranja): IGM PRAGMATIC estimado

Sector/Referencia	IGM Simple	IGM PRAGMATIC
FISMA Federal EE.UU. FY2025	3.7	3.6
ENISA Top Quartile EU	3.6	3.5
Infraestructura Crítica España	3.4	3.2
[NOMBRE ORGANIZACIÓN]	[X]	[X']
AAPP Autonómica media España	2.8	2.5
AAPP Local media España	2.2	1.9

Nota: "La brecha entre IGM Simple e IGM PRAGMATIC se reduce en organizaciones más maduras — señal de que la madurez real conlleva una medición más honesta."

DIAPOSITIVAS 16-20 — ESTRUCTURA DE CIERRE

Diapositiva 16: Las 4 Decisiones del Consejo de Hoy

Cuatro decisiones concretas propuestas:

1. ¿Adoptamos el IGM PRAGMATIC como KPI oficial de ciberseguridad para el ciclo presupuestario?
2. ¿Aprobamos el presupuesto para las 9 métricas de Categoría A (adopción inmediata)?
3. ¿Establecemos el objetivo de IGM PRAGMATIC ≥ 3.5 para el ejercicio 2028?
4. ¿Creamos el Comité de Métricas de Ciberseguridad (CISO + CIO + DPO + responsable calidad)?

Diapositiva 17: Fuentes y Marco de Validación

Lista completa de fuentes del kit (igual que el reporte estándar).

Diapositiva 18: Glosario Visual (para audiencias no técnicas)

Definiciones visuales de: GQM · PRAGMATIC · IGM · ROSI · FISMA · CSF · MTTD · MTTC · ZTA

Diapositiva 19: FAQ Ejecutivo

Las 5 preguntas que siempre hace la dirección:

1. "¿Estamos seguros?" → Respuesta basada en IGM PRAGMATIC
2. "¿Somos mejores que el año pasado?" → Comparativa temporal si disponible
3. "¿Cuánto hay que invertir?" → ROSI verificado
4. "¿Qué pasa si no hacemos nada?" → ALE ajustado
5. "¿Cumplimos la ley?" → Estado de adecuación ENS/NIS2 por artículo

Diapositiva 20: Cierre

Cita de cierre (texto blanco sobre fondo oscuro):

"Una organización que sabe qué no sabe acerca de su ciberseguridad está, curiosamente, más segura que una que cree saberlo todo. La honestidad métrica no es debilidad: es el primer acto de resiliencia."

DIAPPOSITIVAS OPCIONALES (D21-D26)

- D21: Detalle de scoring PRAGMATIC por cada una de las 25 métricas
- D22: Árbol GQM completo (10 objetivos – 29 preguntas – 25 métricas)
- D23: POA&M-GQM detallado con columna de trazabilidad normativa
- D24: Análisis de sensibilidad ROSI (gráfico de tornado)
- D25: Evolución del IGM PRAGMATIC respecto a evaluaciones anteriores
- D26: Plan de mejora de scores PRAGMATIC (roadmap de calidad métrica)

Kit GQM+PRAGMATIC FISMA 2025 — Plantilla Reporte Ejecutivo PowerPoint · Versión 1.0 · Abril 2026